



The Economics of Cybersecurity

Lecture #20

*“Amateurs study cryptography;
professionals study economics”*

- Bruce Schneier



*security is ultimately an economic and human problem, not just a
cryptographic one*

More Schneier-isms

“Amateurs hack systems; professionals hack people”

“Security is not a product, but a process.”

“If you think technology can solve your security problems, then you don’t understand the problems and you don’t understand the technology.”

Recommended reading

<https://www.schneier.com/essays/>

Economics and Cybersecurity

- Cost-benefit analysis: Attackers weigh the cost of breaking into a system against the potential reward. Defenders must do the same when deciding how much to invest in protection.
 - *While attackers only incur the incremental costs of finding a new attack defenders must incur the cumulative costs of defending against all possible attacks.* – Ross Anderson
- Market forces: Companies often prioritize usability, speed, or cost savings over robust security, creating vulnerabilities.
- Incentives: Users, corporations, and governments act according to incentives, not technical ideals. For example, data breaches often occur because organizations underinvest in security until the economic penalties outweigh the savings.

Misaligned Incentives

- Data breaches often occur because organizations under invest in security until the economic penalties outweigh the savings.
- Senior executives often push for rapid innovation, product launches, or cost savings, while CISOs and security teams prioritize risk reduction. Business units are rewarded for speed and revenue, not for secure design. Security teams are left accountable without authority.
- Attackers incur incremental costs (finding a new exploit), while defenders face cumulative costs (covering every possible attack vector).
- Companies with cyber insurance may take fewer precautions, knowing insurers will cover losses. Risk is shifted to insurers, reducing the incentive for firms to invest in prevention.

Economic Significance of Cybersecurity

- The cybersecurity economy has grown faster than the overall global economy, outpacing the tech sector.
- Over 60% of all financial transactions are conducted online, increasing reliance on digital platforms.
- Innovations like AI, blockchain, quantum computing, and cloud services drive economic growth but also introduce new security challenges.
- The digital transformation and globalization have increased dependence on ICT, exposing societies to negative impacts.
- Cyber threats negatively affect company market value, revenue, reputation, and financial policies.
- Publicly disclosed cyber incidents are increasing at an annual rate of 21%, especially in Latin America and higher middle-income countries.

Financial Factors and Cybersecurity Reporting

- US agencies like CISA require reports within 72 hours; some reports, like federal agency breaches, are due in 1 hour. [CERT-IN mandates 6 hours]
- EU mandates include immediate or 24-72 hour reporting, with specific regulations for financial and personal data breaches.
- UK requires 72-hour notifications for cyber incidents; some reports are indefinite.
- Japan, Singapore, and South Korea have reporting windows ranging from 2 hours to 5 days, depending on incident severity.
- The compliance burden is increasing due to complex international regulations and skills gaps.

Security Investment

- Adequate security investment in product/service development
- Adequate security investment in product deployment, support and service delivery
- Adequate security investment in IT ecosystem management

How is adequacy of investment to be determined?

The Gordon-Loeb Model

The Gordon–Loeb model is an economic model that analyzes the optimal level of investment in information security.

The model is based on the reasoning that investing in cybersecurity reduced the costs associated with cybersecurity breaches.

https://en.wikipedia.org/wiki/Gordon%E2%80%93Loeb_model

Description of the Model

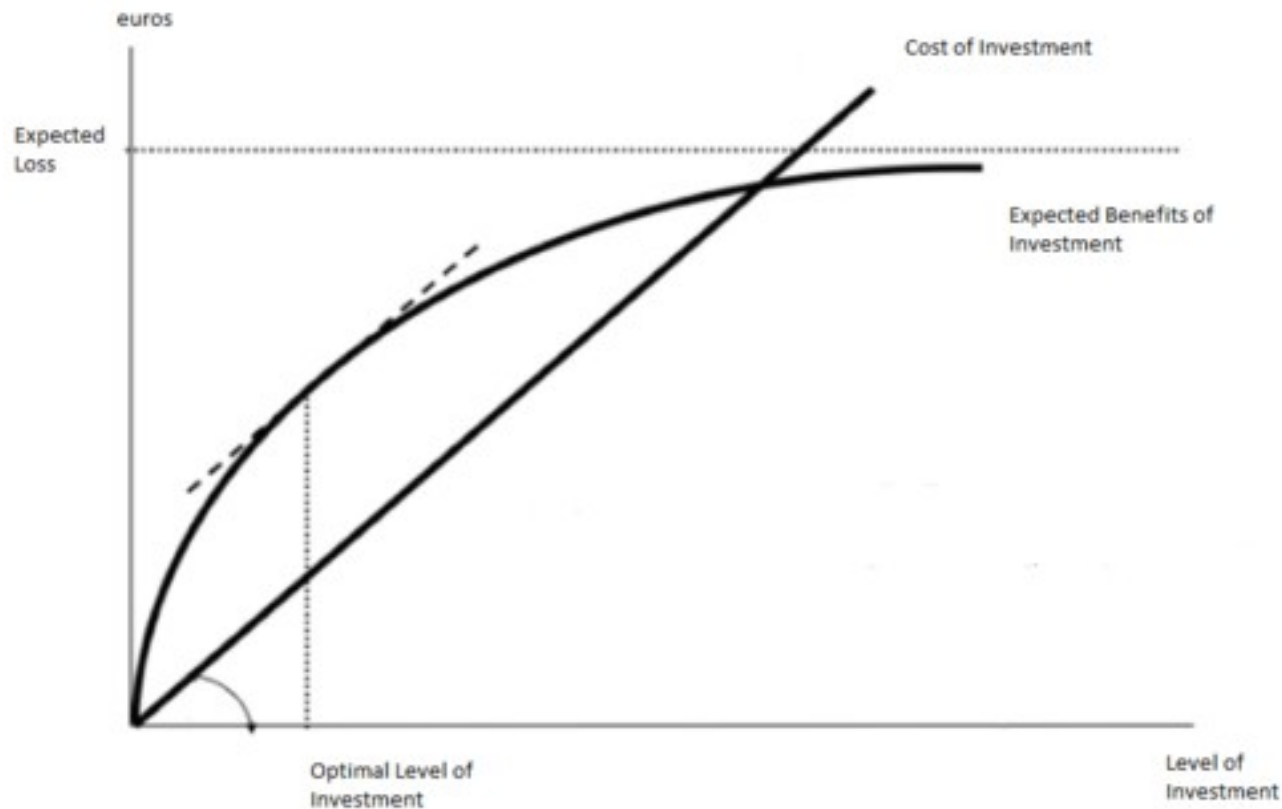
The model includes the following key components:

- Organizational data vulnerable to cyber-attacks, with vulnerability denoted by v ($0 \leq v \leq 1$), representing the probability of a breach occurring under current conditions.
- The potential loss from a breach, represented by L , which can be expressed in monetary terms. The expected loss is calculated as vL before additional cybersecurity investments.
- Investment in cybersecurity, denoted as z , reduces v based on the effectiveness of the security measures, known as the security breach probability function.

Gordon and Loeb demonstrated that the optimal level of security investment, z^* , does not exceed 37% of the expected loss from a breach. Specifically, $z^*(v) \leq (1/e) vL$.

https://en.wikipedia.org/wiki/Gordon%E2%80%93Loeb_model

Illustration



Consider a data value of €1,000,000, with an attack probability of 15% and an 80% chance of a successful breach. The potential loss is $€1,000,000 \times 0.15 \times 0.8 = €120,000$. Based on the Gordon-Loeb model, the company's security investment should not exceed $€120,000 \times 0.37 = €44,000$.

https://en.wikipedia.org/wiki/Gordon%E2%80%93Loeb_model

Critiques and alternative formulations

Subsequent research has critiqued the model's assumptions, suggesting that some security breach functions may require fixing no less than $1/2$ the expected loss, challenging the universality of the $1/e$ factor. Alternative formulations even propose that some loss functions may justify investment at the full estimated loss.

References

Gordon, Lawrence A.; Loeb, Martin P. (November 2002). "The Economics of Information Security Investment". ACM Transactions on Information and System Security. 5 (4): 438–457. doi:10.1145/581271.581274. S2CID 1500788.

Willemson, Jan (2006). "On the Gordon&Loeb Model for Information Security Investment". WEIS.

https://en.wikipedia.org/wiki/Gordon%E2%80%93Loeb_model

Practical Estimation Methods

While the Gordon-Loeb model is a theoretical model to estimate cybersecurity investment, its assumptions make it unsuited to a practical determination of how much an organisation should spend on cybersecurity. This model makes some assumptions about the form of the function that reduces vulnerabilities as a function of investment. Therefore while this is an useful conceptual construct its practical relevance is somewhat limited.

We have the following options

- Estimate the security resources needed (and therefore the investment) using a work-break-down type method based on some security framework
- Estimate security expenditure based on some organisational metrics

Estimation based on work-break-down

This method involved using some security framework like the ISO 27001/NIST CSF/CIS top 18/CERT-IN guidelines to determine what needs to be done.

This needs to be preceded by a risk assessment to determine which controls are applicable and to what level of rigour and sophistication the control needs to be implemented. In the context of the chosen framework and the risk assessment a clear idea of the “work” that is required to be done emerges and the investment is calculated based on what it will take to do that “work”

In assignment 02 you carried out this activity for IIT Bombay in the context of CERT-IN guidelines but without any guiding risk assessment

Estimation based on organisational metrics

- Can we use some measure of size of the organization
 - Employees?
 - Turnover?
 - IT users?
 - Something else?
- Can we use the total IT budget and estimate security spend as a percentage of that?
- Can we compare with what others that are “similar” are spending?

Some Recommendations & Best Practices

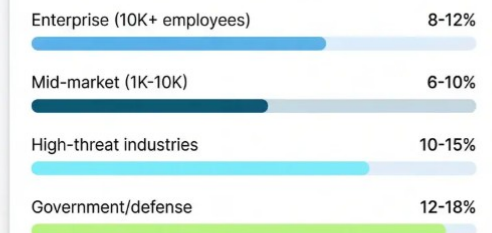
Analyst Firm	Recommended % of IT Budget	Key Notes
Gartner	8–12% (10–15% for high-risk)	Provides detailed allocation breakdown across software, personnel, hardware, and services
Forrester	7–12% (risk-adjusted)	Emphasizes tailoring spend to risk, compliance, and operational maturity

Industry	Avg Breach Cost	Key Budget Priority	Microseg Investment	Compliance Driver
Healthcare	\$7M+ (highest)	Medical device security: 20–25% of budget	\$1–4M initial, \$400K–\$1.2M/yr ops	HIPAA mandatory segmentation
Manufacturing	\$4.56M (OT)	OT/IT segmentation, IP protection: 15–20%	IEC 62443: \$3–8M, 18–36 months	IEC 62443, FDA OT guidance
Critical Infrastructure	Varies	SIEM, IR, compliance programs	10–15% of budget for compliance	CIRCA May 2026, NERC CIP

2026 Cybersecurity Budget Allocation



IT Budget to Security by Org Type



Gartner projects \$240B global cybersecurity spending in 2026
 ↗ 12.5% YoY increase

<https://www.elisity.com/blog/2026-cybersecurity-budget-complete-enterprise-planning-guide>

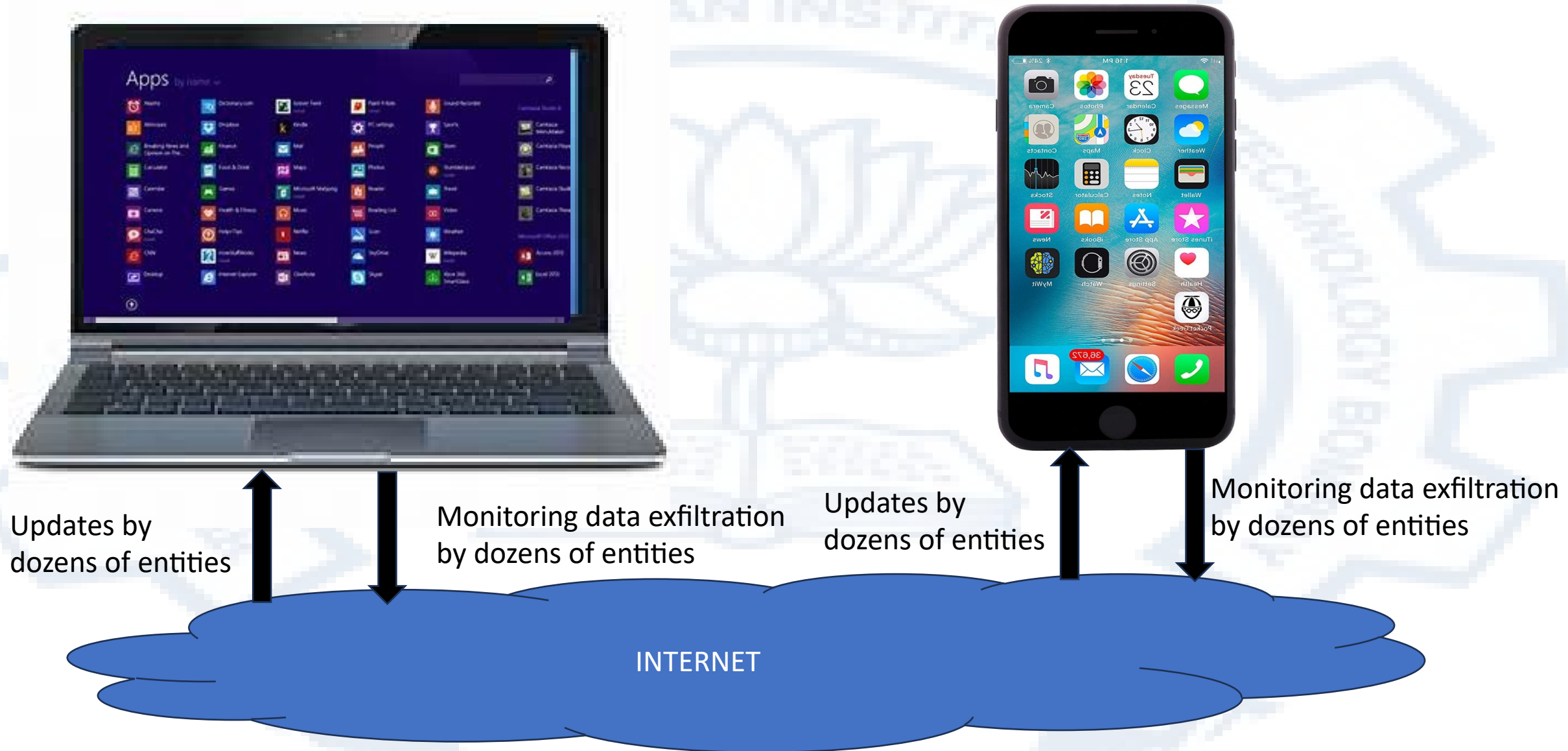
Some Factors Driving up Budgets Globally

- AI-powered threat evolution. Attackers can now generate 10,000 personalized phishing emails per minute using generative AI, rendering static defenses insufficient.
- Deepfake fraud surge. Deepfake-enabled fraud incidents increased 3,000% in 2024, forcing organizations to reassess authentication and identity verification controls.
- Board-level engagement. Cybersecurity is now recognised as a core fiduciary duty, with directors and officers increasingly accountable for security posture.
- Regulatory pressure. New and evolving compliance mandates (CMMC 2.0, CIRCIA, updated HIPAA, IEC 62443) are creating mandatory spending floors that can't be deferred.
- In India highly regulated entities are feeling this pressure but spending in the average enterprise falls short of global benchmarks

Evolution of Software Distribution

- In the early days software was distributed on media like CDs. It had to be installed on each endpoint device manually
- With the increasing availability of the Internet the practice changed to requiring users to download it to their computers
- Having a “default deny” type of environment meant more helpdesk calls to a “default allow” type of culture took root
- The nature of software and the discovery of vulnerabilities required software to be updated. In the early days these updates/upgrades/patches were made available and users were expected to periodically download and apply them.
- Due to a combination of economic, operational and intellectual property protection concerns we have moved to a situation where a lot of software is provided in a SaaS model. This allows continuous updates happening in the back end without the user’s intervention (and even knowledge)

What is happening on our devices ? - NFI



The Crowdstrike Incident

- 18th July 2024 –
 - Late on the 18th night, Many reports emerge of Windows computers displaying the blue screen of death. Only Windows computers are affected. There are no reports of Mac or Linux computers being impacted.
 - Within a few hours the security firm Crowdstrike confirms that a faulty security update for its Falcon sensor caused Windows computers, with that software installed, to crash
- 19th July 2024 –
 - Crowdstrike issues an advisory admitting that a faulty content update was responsible and that the problem was limited to Windows computers. The advisory contains instructions on how to remediate affected systems and identify systems that could possibly have been impacted.
 - At about the same time Microsoft reports a significant outage in its Azure Central US region. Allegedly a Microsoft person speaking to Techcrunch said that its outage was not related to the Crowdstrike incident¹.
 - On Friday at about noon US EST, Satya Nadella posts a message on X saying that Microsoft was aware of the Crowdstrike incident and was working with them to restore systems

1. <https://techcrunch.com/2024/07/19/what-we-know-about-crowdstrikes-update-fail-thats-causing-global-outages-and-travel-chaos/>



AirAsia passengers wait to be checked in manually at Kuala Lumpur International Airport's Terminal 2, after a global IT system outage, in Sepang, Malaysia, July 19, 2024. *Hasnoor Hussain, REUTERS*



A blue error screen on a register is seen at a departmental store affected by a cyber outage in Brisbane, Australia, July 19, 2024. *AAP, Via REUTERS*



A notice informing customers they cannot pay by card is displayed in the self-checkout area of a Waitrose supermarket, amid a global IT outage, in Canary Wharf, London, Britain, July 19, 2024. *HELEN REID, REUTERS*



United Airlines employees wait by a departures monitor displaying a blue error screen, also known as the "Blue Screen of Death" inside Terminal C in Newark International Airport, after United Airlines and other airlines grounded flights due to a worldwide tech outage caused by an update to CrowdStrike's "Falcon Sensor" software. *Bing Guan, REUTERS*

What CrowdStrike says

- CrowdStrike realized that the UTC 2024-07-19 0409 file had a flaw and released another version addressing the flaw at UTC 2024-07-19 0527¹
- CrowdStrike published the technical details of the outage at UTC 2024-07-20 0100²
- The Preliminary Post Incident Review(P-PIR)³ states that there is a type of Rapid Response Content that is delivered by means of “Template Instances” which are instantiations of “Template Types”
- Template Types are tested, but template instances are “validated”

Newly released Template Types are stress tested across many aspects, such as resource utilization, system performance impact and event volume. For each Template Type, a specific Template Instance is used to stress test the Template Type by matching against any possible value of the associated data fields to identify adverse system interactions.

Template Instances are created and configured through the use of the Content Configuration System, which includes the Content Validator that performs validation checks on the content before it is published.

(Underline added by author)

1. <https://www.crowdstrike.com/falcon-content-update-remediation-and-guidance-hub/>
2. <https://www.crowdstrike.com/blog/falcon-update-for-windows-hosts-technical-details/>
3. <https://www.crowdstrike.com/falcon-content-update-remediation-and-guidance-hub/>

What Microsoft says

- Microsoft claims that CrowdStrike had access to the kernel because the EU required them to provide kernel access to Windows by virtue of an undertaking¹ that Microsoft gave to the EU in 2019.

Microsoft gives the following Undertaking to address the competition concerns raised in Case No. COMP/C-3/39.294 which are based on its interpretation of the legal and economic principles deriving from Article 82 of the EC Treaty and the judgment of the Court of First Instance of the European Communities of 17 September 2007 in Case T-201/04 Microsoft v Commission.

- As part of the Specific Commitments set forth in the undertaking is that

Microsoft shall ensure on an ongoing basis and in a Timely Manner that the APIs in the Windows Client PC Operating System and the Windows Server Operating System that are called on by Microsoft Security Software Products are documented and available for use by third-party security software products that run on the Windows Client PC Operating System and/or the Windows Server Operating System. These APIs will be documented on the Microsoft Developer Network, unless open publication would create security risks. In such circumstances, Microsoft will provide third-party security vendors with access to such APIs pursuant to a royalty-free license and on fair, reasonable and non-discriminatory terms.

1. <https://news.microsoft.com/download/archived/presskits/eu-msft/docs/MicrosoftInteroperabilityUndertaking16Dec2009.doc>

The Financial Impact: Who will pay for it- 1

- Direct impact to Microsoft - *Microsoft shares fell less than 1% to \$437.11¹.*
- Direct impact to CrowdStrike - *Shares of CrowdStrike dropped 11% to \$304.96 in New York trading, wiping out more than \$9 billion in market value¹.*

https://economictimes.indiatimes.com/news/company/corporate-trends/microsoft-cloud-outage-from-atms-to-stock-trading-and-flights-epic-it-crash-leaves-trail-of-chaos/articleshow/111875663.cms?utm_source=contentofinterest&utm_medium=text&utm_campaign=cppst

The stocks will most likely recover quickly. Ironically this may result in further spending on IT which in turn may take tech stocks higher!!

The Financial Impact: Who will pay for it- 2

- Direct costs incurred by third parties : Impacted parties will bear these costs
 - Missed flights, failed transactions
 - Lost productivity
 - Costs of fixing the systems to recover and test integrity
 - It remains to be seen how many impacted parties had insured against such incidents and whether insurance companies will pay
- Consequential costs incurred
 - Opportunity costs
 - Costs occurring due to liability of failing to discharge obligations
- Is CrowdStrike liable?
- Is Microsoft liable?

It's not just laptops and phones



The Policy Questions

- How should IT/Technology/Cyber risk be assessed and reported?
- Should it be possible for software providers to continue to disclaim all liabilities for malfunctions?
- Should the processes required to deliver IT services be standardized and subject to regulation?
- Should there be a definition of critical IT services where regulation has a higher level of stringency and rigour?
 - Assurance to follow standards
 - Mandatory audit
 - Mandatory requirement to disclose risk assessment and possible impact on the basis of the mandatory audit results
 - Where to allow automation
 - How to carry out changes

Summary

- Cybersecurity is a socio-techno-economic problem. Technology only approaches have very little chance of succeeding in at-scale deployments
- Products, systems and services are vulnerable and those vulnerabilities need investment to be reduced
- Theoretical models to estimate optimal cybersecurity investments exist but their assumptions are not realistic
- In practice the methods used to determine investment in cybersecurity are some form of work-breakdown based on frameworks such as ISO/IEC 27000 or NIST CSF or the CERT-IN guidelines for government entities or something else
- Benchmarking using organizational size and sector methods are also used but these are used more to validate the results of some work-breakdown rather than as the primary method
- The cost of cybersecurity incidents are becoming difficult to estimate quantitatively. This is because we now operate in cyber ecosystem where individual organisations have relatively low control over the ecosystem
- This raises policy questions about liability and software producers have so far resisted efforts to make them accept liability